

NAME: KRITHIKA M

REGISTER NUMBER: 192521385

COURSE: CSA 5802 DEVSECOPS

CO 2 PART 2

Cloud Infrastructure Attack Surface Analysis and Misconfiguration Case Study

Executive Summary

Cloud adoption has expanded the effective perimeter of most organizations from a small set of managed data centres to a sprawling, API-driven surface spanning storage buckets, identity systems, serverless functions, container registries, and third-party integrations. This expansion delivers agility, but it also multiplies the number of places where a single misconfiguration can expose sensitive data or grant unintended access. This case study examines how cloud attack surfaces are mapped and assessed, catalogues the misconfiguration patterns most frequently responsible for real-world breaches, and walks through a composite incident modeled on publicly reported cloud data-exposure events. The goal is to give security teams, cloud architects, and risk owners a practical reference for identifying similar weaknesses in their own environments before an attacker does.

The analysis finds that the majority of high-impact cloud incidents do not stem from novel exploits against the cloud provider's infrastructure. Instead, they result from avoidable configuration errors: overly permissive identity and access management (IAM) policies, publicly accessible storage, unencrypted data at rest or in transit, exposed management interfaces, and inadequate logging that delays detection. Addressing these issues requires a combination of automated configuration scanning, least-privilege identity design, and continuous monitoring rather than any single tool or product.

1. Understanding the Cloud Attack Surface

The attack surface of a cloud environment is the sum of all points where an unauthorized party could attempt to enter, extract data from, or manipulate a system. Unlike a traditional on-premises network, a cloud attack surface is dynamic: resources are created and destroyed programmatically, ownership is

often distributed across many teams, and a large share of the surface is directly reachable from the public internet by default in some services.

1.1 Core Components of the Cloud Attack Surface

- Identity and Access Management (IAM): users, roles, service accounts, access keys, and the policies that govern what each can do.
- Storage services: object storage buckets, managed databases, snapshots, and backups.
- Compute and orchestration: virtual machines, containers, serverless functions, and their runtime configurations.
- Networking: virtual private clouds, security groups, load balancers, and exposed management ports.
- APIs and management planes: the control-plane endpoints used to configure the environment itself.
- Third-party and supply-chain integrations: CI/CD pipelines, external SaaS connections, and shared credentials.

Attack surface analysis is the structured process of enumerating these components, determining which are internet-facing or otherwise reachable, and evaluating whether their configured permissions match their intended purpose. It is typically performed continuously, since the surface changes with every deployment.

2. Common Cloud Misconfiguration Patterns

Industry incident data consistently points to a small number of recurring misconfiguration categories. The table below summarizes the patterns most relevant to this case study, along with their typical root cause and consequence.

Misconfiguration	Typical Root Cause	Potential Consequence
Publicly readable storage buckets	Default or manually changed access-control setting left open	Bulk exposure of sensitive files or backups
Overly broad IAM policies	Wildcard permissions granted for convenience during development	Privilege escalation, lateral movement

Misconfiguration	Typical Root Cause	Potential Consequence
Exposed management consoles or APIs	Security group or firewall rule left open to 0.0.0.0/0	Direct compromise of infrastructure control plane
Unencrypted data at rest	Encryption not enabled at resource creation	Data readable if storage is exposed or stolen
Hard-coded credentials	Access keys embedded in code or container images	Credential theft via source code or image scanning
Insufficient logging and monitoring	Logging disabled or not centralized	Delayed detection, incomplete incident response
Orphaned or forgotten resources	Test or legacy assets not decommissioned	Unpatched, unmonitored entry points

3. Case Study: Composite Incident Analysis

The scenario below is a composite, illustrative case built from patterns commonly reported in public post-incident disclosures and industry breach reports. It does not describe any single real organization; names and details are fictional. It is presented to illustrate how individually minor misconfigurations combine into a serious exposure.

3.1 Background

"NorthBridge Retail," a mid-sized e-commerce company, migrated its customer analytics platform to a public cloud provider over an 18-month period. The migration was driven by two separate engineering teams working with limited shared governance: a platform team responsible for core infrastructure, and an analytics team responsible for data pipelines. No centralized cloud security posture management (CSPM) tooling was in place at the time of the incident.

3.2 How the Exposure Developed

- The analytics team provisioned an object storage bucket to stage raw customer order exports for a reporting pipeline.
- During initial testing, a developer set the bucket's access policy to allow public read access to simplify debugging from a personal laptop, intending to revert the change after testing.
- The reversion was never completed; no ticket or change-control record tracked the temporary setting.
- Because the bucket sat outside the platform team's tagging convention, it was excluded from the periodic access review spreadsheet the platform team maintained manually.
- Separately, a CI/CD pipeline used by the analytics team stored a long-lived cloud access key as a plaintext environment variable, rather than using short-lived, role-based credentials.
- That key had broad read permissions across storage services, granted originally to simplify a one-time migration task and never scoped down afterward.

3.3 Discovery

The exposure was identified not by internal monitoring but by an external security researcher conducting routine internet-wide scanning for publicly readable storage buckets. The researcher notified the company through its published responsible-disclosure contact. Internal logs later showed the bucket had been publicly accessible for approximately eleven weeks, though the organization's

logging configuration only retained partial access logs for the final three weeks, limiting the ability to fully determine whether the data had been accessed by other parties during the exposure window.

3.4 Root Cause Analysis

The incident review identified the following contributing factors, each individually minor but jointly sufficient to create a significant exposure:

Contributing Factor	Category
Bucket access policy manually set to public during testing	Storage misconfiguration
No change-control process for temporary configuration changes	Process gap
Resource excluded from access review due to inconsistent tagging	Governance gap
Long-lived, over-permissioned access key stored in plaintext	Credential and IAM misconfiguration
Incomplete log retention limiting forensic visibility	Monitoring and logging gap
No automated cloud security posture scanning in place	Tooling gap

3.5 Impact

The exposed dataset contained order records including customer names, shipping addresses, and partial order histories; payment card data was not included, as that was tokenized and stored separately through the company's payment processor. The company notified affected customers and relevant regulators in line with applicable data-breach notification requirements, engaged an external forensics firm, and faced reputational impact along with the direct costs of investigation, notification, and credit-monitoring services offered to affected customers.

4. Attack Surface Analysis Methodology

Preventing incidents like the one above depends on treating attack surface analysis as a continuous discipline rather than a one-time audit. A practical methodology includes the following stages.

4.1 Asset Discovery and Inventory

Maintain an automatically generated, continuously updated inventory of all cloud resources, including storage, compute, identities, and network configurations, tagged by owner and environment. Manual spreadsheets, as in the case study, are unreliable at scale and become stale quickly.

4.2 Exposure Mapping

For each asset, determine whether it is reachable from the public internet, from other internal environments, or only from a tightly scoped set of trusted sources. This mapping should be regenerated on every significant infrastructure change, not on a fixed calendar cycle.

4.3 Permission and Policy Review

Evaluate IAM policies, storage access controls, and network rules against least-privilege principles. Flag wildcard permissions, unused permissions, and credentials that have not been rotated within policy-defined intervals.

4.4 Continuous Monitoring and Alerting

Centralize logging across all cloud services, retain logs for a duration sufficient to support forensic investigation, and configure alerting for high-risk events such as a storage resource's access policy changing to public, or an access key being used from an unexpected location.

5. Recommendations

- Deploy cloud security posture management (CSPM) tooling to continuously scan for public storage, excessive permissions, and configuration drift.
- Require change-control tickets for any temporary relaxation of access controls, with automated expiry and reversion.
- Replace long-lived static access keys with short-lived, role-based credentials tied to specific tasks or pipelines.
- Enforce consistent resource tagging and ownership metadata at the infrastructure-as-code level so no asset can be provisioned outside governance review.
- Set minimum log retention periods that align with realistic incident-investigation timelines, and centralize logs across teams and services.
- Run periodic access reviews that are generated from the live resource inventory rather than maintained manually.

- Conduct regular tabletop exercises simulating public data exposure to validate detection and response readiness.

6. Conclusion

The case examined here illustrates a pattern seen repeatedly across publicly documented cloud incidents: no single catastrophic failure caused the exposure. Instead, a chain of small, individually explainable decisions, a temporary public-access setting, a missing tag, an over-scoped key, and an incomplete log retention policy, combined to create a significant and prolonged data exposure. This underscores the central lesson of cloud attack surface analysis: security posture must be continuously verified against the environment as it actually exists, not as it was designed or documented, because cloud environments change far faster than manual review processes can track.